

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 2 Practical Laboratory

Developing Security Policies and Procedures

Student Information	
Full Name	Khodani Netshifhefhe
Registration Number	C11/26/CGRCE/17580
Email Address	c11.cgrce2617580@icdfa.edu.ng
Submission Date	18 September 2026

Task 1 Establish the Security Policy Hierarchy

Evidence Bundle 1: Policy hierarchy, hierarchy diagram and statement categorisation.

Document Type	Purpose	Authority/Owner	Mandatory or Recommended	Level of Detail
Policy	Policy defines the rules, technologies, and practices required to protect an organization's digital assets, physical property, and employee data. It answers why the organization acts and establishes accountability and scope.	Executive level leadership such as CEOs or CISO	Mandatory	Low - it focuses on principles and business requirements rather than technical instructions.
Standard	It converts the requirements in a policy into specific, measurable security requirements. It explains what must be in place to meet the policy.	It is owned by the relevant security or IT function and approved by the appropriate risk or security authority.	Mandatory	Medium - detailed enough to be measured and audited, but not down to individual steps or commands.
Guideline	Provides recommended practices that help employees and technical teams apply security requirements appropriately. It explains what is advisable rather than creating a strict requirement.	Usually issued by the Information Security or IT team and maintained by the relevant subject-matter experts.	Recommended	Medium - provides practical advice without prescribing every action.
Procedure	Procedures provide clear step-by-step instructions for completing a specific security or operational task. It	Maintained by the operational or technical team responsible for carrying out the task.	Mandatory	High - detailed and task specific, including the sequence of actions and technical steps

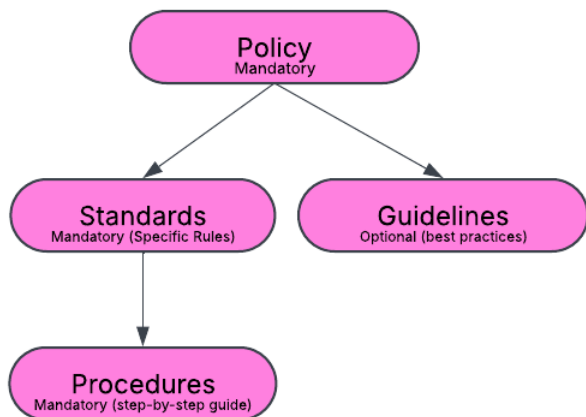
	explains how to do something.			where necessary.
--	-------------------------------	--	--	------------------

Categorisation table for all eight statements, with a one-sentence justification for each classification.

Statement	Classification	Justification
All NexusTech employees must use multi-factor authentication (MFA) when accessing the corporate network remotely.	Standard	It is a mandatory security control requirement supporting the broader access-control policy, but it is not yet a technical how procedure
To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	It is a step-by-step instructions on how to successfully download and enroll on to MFA.
It is recommended that developers use parameterized queries to reduce SQL injection risk.	Guideline	The statement uses advisory language 'recommended' rather than mandatory language 'must'. It outlines a preferred best practice to mitigate risk while leaving room for developers to use alternative security controls for coding best practices.
NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	This is a principle-based statement of management intent with no technical detail.
All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	This is a mandatory, specific, testable control that operationalises a data-protection policy.
Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	It depends on employee context or judgement rather than being hard control.

In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	Immediate instructions to follow within the incident response process with the step by step actions.
Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.	Standard	A mandatory, testable technical baseline that operationalises a broader access-control or password policy.

A simple hierarchy diagram showing how policy flows into standards, procedures and guidelines.



By Khodani Netshifhefhe

Task 2 Draft an Effective Acceptable Use Policy (25 marks)

Evidence Bundle 2: Completed Acceptable Use Policy.

Document Control

Field	Entry
Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027

1. Purpose

This policy defines the acceptable and prohibited use of NexusTech Solutions (NexusTech) information systems, devices, networks, and accounts. It exists to protect the confidentiality, integrity and availability of company and client data including data belonging to NexusTech's financial and healthcare clients. The goal is to reduce the risk of malware infection, data loss, unauthorized access, and regulatory non-compliance.

2. Scope

This Policy applies to:

- **All users:** All full-time, part-time, temporary, and contract employees, vendors, consultants, third-party partners, and any other individuals granted access to NexusTech resources.
- **Assets and Systems:** All physical and virtual assets owned, leased, or managed by NexusTech, including but not limited to company-provided laptops, desktop computers, mobile devices, servers, cloud services, software applications, corporate emails, wired and wireless corporate network infrastructure
- **Locations:** Use of NexusTech assets and systems from any location, whether on company premises, remotely, or whilst traveling.

3. Policy Statements

3.1. Acceptable Use

- **Business Operations:** NexusTech IT assets and networks are provided primarily for business-related purposes. Users are expected to use these tools efficiently, ethically, and professionally
- **Data Protection and Confidentiality:** Users must keep corporate data safe, customer records, intellectual property, and proprietary information. Confidential data must only be accessed, processed, and transmitted through approved channels and devices.
- **Accountability and Authentication:** Access to credentials such as usernames, passwords, multi-factor authentication tokens, and PINs are personal and non-transferable. Users are individually accountable for all activities conducted under their credentials. Passwords must be unique, complex, and updated according to organizational password guidelines.
- **Asset Safeguarding:** Users must exercise reasonable care to protect physical company equipment against loss, theft, damage, or unauthorised access. Laptops and mobile devices must never be left unattended in public spaces.
- **Clean Desk:** Users must observe clean desk and clear screen practices, ensuring sensitive information and unattended devices are not left accessible in shared or public spaces.

3.2. Prohibited Activities

The following activities are strictly prohibited on any NexusTech asset, network, or system, regardless of location:

- **Unauthorized Software and System Changes:** Users must not download, install, or execute unapproved software, applications, or browser extensions, and must not attempt to bypass, disable, or modify security controls, including endpoint protection, encryption, multi-factor authentication, or web content filtering.
- **Data Handling Violations:** Users must not store, process, or transmit NexusTech or client data particularly regulated financial or healthcare data through personal email accounts, personal cloud storage, or any third-party service not formally approved by IT/Security. Removing NexusTech or client data from the company's systems for personal retention or external use is also prohibited
- **Unauthorized Access:** Users must not attempt to access systems, data, or accounts beyond what is required for their role, or attempt to bypass authentication controls to gain elevated or unauthorized privileges.
- **Network and Device Misuse:** Users must not connect unauthorized personal devices, removable media, or peripherals to NexusTech systems in a manner that

bypasses security controls, and they must not use NexusTech network resources to operate personal servers, mining software, or unauthorized file-sharing services.

3.3. Reasonable Personal Use

NexusTech recognizes that employees may occasionally need to handle personal matters during work hours using corporate assets. Incidental personal use is permitted provided that it strictly adheres to the following conditions:

- **Frequency & Impact:** Personal use must be minimal, reasonable scheduled breaks. It must not interfere with job performance or day to day business.
- **Resource Usage:** Personal use must not consume excessive network bandwidth, storage space, or compute capacity.
- **Compliance:** All personal activities conducted on corporate devices or networks remain fully subject to this AUP. There is no right or expectation of privacy regarding personal communications or activities conducted on NexusTech systems.

4. Roles and Responsibilities.

Roles	Responsibilities
Users (Employees, Contractors, Third Parties)	Read, understand, and comply with all provisions of this AUP. Maintain confidentiality of authentication credentials and avoid sharing access. Promptly report suspicious activities, security incidents, lost or stolen equipment, or potential policy breaches to IT/Security.
IT & Information Security Team	Maintain, monitor, and enforce technical controls supporting this policy (e.g., endpoint security, software restrictions, web filtering). Ensure prompt patching and system maintenance to mitigate risk. Review incident reports, conduct investigations, and escalate non-compliance matters. Conduct regular security awareness and training programs.
Managers & Supervisors	Ensure team members under their supervision understand and adhere to this policy. Take swift and appropriate action when informed of policy breaches within their department. Coordinate with HR and

	IT/Security when onboarding or offboarding employees or handling disciplinary actions.
Human Resources (HR)	Incorporate the Acceptable Use Policy into the employee onboarding process and maintain documentation of user acknowledgments. Assist in disciplinary processes arising from policy violations in accordance with corporate employment standards.

5. Compliance and Enforcement

5.1 Compliance with this policy is mandatory for all individuals in scope.

5.2 IT/Security may monitor systems, network traffic and device activity to the extent permitted by law and company policy, for the purposes of security, compliance and enforcement.

5.3 Suspected violations must be reported to IT/Security or a direct manager without delay.

5.4 Confirmed violations may result in disciplinary action up to and including termination of employment or contract, and may be referred to law enforcement or regulators where required by law or contractual obligation (e.g. client agreements in financial or healthcare sectors).

5.5 Compliance with this policy will be assessed periodically as part of internal audit and ISO/IEC 27001 / SOC 2 readiness activities.

6. Exceptions

6.1 Exceptions to this policy may be requested where a legitimate business need cannot be met through compliant means.

6.2 Exception requests must be submitted in writing to the Information Security Manager, must state the business justification, scope, duration and compensating controls, and must be approved before the non-compliant activity begins.

6.3 All approved exceptions must be time-bound, documented in the exception register, and reviewed at expiry or at the next policy review, whichever comes first.

6.4 No exception may be granted that would result in unlawful activity or unauthorised exposure of client data.

7. Approval and Review

Action	Name/Role	Date
Prepared by	Khodani Netshifhefhe (Information Security Manager)	16 September 2026
Approved by	Marcus Vance (Chief Executive Officer)	
Effective Date		18 September 2026
Next Review Date		18 September 2027

Task 3 Create an Actionable User Access Request Procedure (20 marks)

Evidence Bundle 3: Completed User Access Request Procedure.

Field	Entry
Title	User Access Request Procedure
Version	2.0
Document Owner	Information Security Manager
Approval Authority	IT Director
Effective Date	18 September 2026
Review Date	18 September 2027
Supports	Acceptable Use Policy v1.0

1. Purpose

To define a consistent, auditable process for requesting, approving, and provisioning access to NexusTech systems, replacing informal email/chat requests.

2. Scope

This procedure applies to all Helpdesk technicians, system administrators, and IT employees handling user access. It covers all access requests including new hires, role changes, temporary contractor access, and elevated privileges across all NexusTech systems, applications, and networks.

3. Prerequisites

- Requests are logged only via the ITSM ticketing system.
- Requester must be the user's manager or the relevant data/system owner.
- A current role-based access catalogue.
- A current authorized-approvers list per system.
- Only technicians with provisioning rights on the target system may provision.

4. Steps / Procedure

Step 1: Log the request and confirm submission through the ITSM "Access Request" ticket type. Kindly redirect any email or chat request to the ITSM. The ticket must capture the requester's name, user's name, system, access level, justification, and start date.

Step 2: Validate the requester's authorization, confirm if they are the user's manager or the relevant data/system owner. Reject and redirect if not.

Step 3: Verify approval. Confirm the recorded approval from the manager.

Step 4: Match role-based access. Map the user's role to the access catalogue. If the request matches the standard bundle, proceed. If it exceeds the user's expected role, escalate to the Information Security Manager first.

Step 5: Apply least privilege. Confirm the access is the minimum needed and doesn't duplicate existing access. Record the outcome of the ticket.

Step 6: Provision the account. Create or modify access in the system's standard provisioning tool, per the approved bundle only. Set an initial credential per the Password Standard which requires reset upon initial login and enroll MFA where required.

Step 7: Notify. Notify the user via email directly with login/MFA instructions and notify the requesting manager that the request is complete. Log both notifications with timestamps.

Step 8: Capture evidence and close.

5. Emergency or Exceptional Requests

- Applies when standard approval can't be obtained in time to prevent significant impact.
- Requester still logs a ticket, marked "Emergency," with business justification.
- A technician may provision only with verbal/written sign-off from the Information Security Manager or IT Director.
- Access is minimum-necessary and time-bound to 72 hours.
- Written approval must follow within 2 business days, or access is revoked immediately and escalated.

6. Record Keeping & Auditing

- Keep all access tickets, approval notes, and evidence of screenshots in the ServiceDesk database for at least 5 years.
- Closed tickets are not edited or deleted; corrections are added as linked entries.
- IT and Security will run quarterly audits comparing active accounts against closed tickets to catch and remove any orphan or extra accounts

Task 4 Policy Implementation and Communication (20 marks)

Evidence Bundle 4: Communication and Training Plan.

Field	Entry
Title	AUP Communication and Training Plan
Version	1.0
Owner	Information Security Manager
Effective Date	18 September 2026

1. Plan by Audience

Audience	Key Message	Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	Understand what's acceptable or prohibited on company devices and networks, and that they're personally accountable for their account activity.	All-Hands Town Hall kickoff, Intranet news banner, and a 15-minute interactive LMS module.	Information Security Manager and HR	1-2 Weeks	Digital completion badge	More than 95% completion and attestation rate within 14 days.
IT/Helpdesk Staff	Technical enforcement rules, strict ticket-only provisioning, verifying data owner sign-offs, least-privilege checks, and emergency override workflows.	Dedicated workshop and walkthrough of updated ticketing workflow	IT Director	Week 1	Sign-off on workshop attendance and procedure walkthrough	100% attendance;
Managers/Supervisors	Understand their approval authority, responsibility to escalate breaches,	Manager briefing session and one-page responsibilities summary	Information Security Manager	Week 2	Signed acknowledgment of responsibilities summary	100% acknowledgment within 2 weeks of session

	and role in onboarding or offboarding access.					
New Joiners	AUP compliance is a condition of receiving system access same expectations as existing staff, from day one.	Mandatory e-learning module built into onboarding checklist	HR and IT Security	1 st Week	Digital attestation required before Access Request Procedure grants any system access	100% of new hires attested during onboarding

2. Rollout Timeline

Week	Activity
Week 1	CEO-signed announcement issued, IT/Helpdesk workshop delivered
Week 2	Manager briefing sessions; e-learning module and intranet notice launched organisation wide
Week 3-4	Completion/attestation report compiled and non-completers followed up by managers
Week 5	Completion report is compiled and non-completers followed up by managers
Week 8	30 day post-rollout knowledge-check survey and effectiveness review is reported to CEO
Ongoing	New joiners complete the e-learning module and attestation as a standing onboarding step and HR will confirm attestation before requesting account provisioning under the Access Request Procedure

3. Acknowledgement Mechanism

All employees must complete a digital attestation within the e-learning platform confirming they have read, understood, and agree to comply with the AUP. Attestation is timestamped, tied to the employee's identity, and stored as an HR record. For new joiners, attestation is a hard gate rather than a campaign deadline HR includes the e-learning module in the onboarding checklist.

4. Effectiveness Measures

- **Completion/attestation rate:** Percentage of in-scope users who complete training and attestation within the 4-week window (target more than 95%).
- **Knowledge-check pass rate:** Percentage of users passing the embedded quiz on first attempt (target more than 85%), indicating comprehension rather than just click-through completion.
- **New-joiner attestation rate:** Percentage of new hires attested before account provisioning, tracked monthly as an ongoing BAU metric rather than a one-time rollout figure (target is 100%).

5. Escalation for Non-Compliance or Misunderstanding

Non-completion of training escalates on a fixed timeline. Users will get a reminder on day 7 if it goes on, managers will get notified at day 14, and HR at day 21 with possible access review. Confirmed policy violations, regardless of training status, follow the AUP's own Compliance and Enforcement process through IT/Security and HR. New joiners who haven't attested simply can't get provisioned at all.

Task 5 Policy Review and Maintenance (15 marks)

Evidence Bundle 5: Policy Review and Maintenance Memo.

The Acceptable Use Policy requires a formal review before its annual scheduled date, triggered by two independent events over the past year. Namely, the migration of the primary database to AWS changes the technical environment. Secondly, an employee shared a sensitive document via personal cloud storage, indicating the existing prohibition was either unclear or poorly communicated.

To assess these, the review will trigger stakeholder consultation with IT/Cloud Engineering, the Data Protection lead, and Legal/Compliance to confirm how AWS-hosted data is classified and secured. A risk analysis of the incident's root cause and whether similar exposure exists elsewhere will be performed and an evidence review of training completion and attestation records to confirm whether affected staff had acknowledged the relevant AUP clause must be done.

Based on this, I am proposing two updates which are, explicitly defining "approved cloud services" to distinguish NexusTech-sanctioned infrastructure, including the new AWS environment, from prohibited personal cloud storage. The second proposal is a request to add a specific data-handling clause requiring sensitive documents to be shared only via approved tools with logging or Data Loss Prevention controls, rather than relying on the current general "approved channels only" language.